

VULNERABILITY AND PATCH MANAGEMENT POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Vulnerability and Patch Management Policy
Document ID	POL-VPM-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC4.1, CC4.2 and CC7.1, and GDPR Article 32. Scanning runs automatically; the human cadence is annual.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 WHAT IS SCANNED6

6 DECIDING WHAT MATTERS6

7 FIXING AND CONFIRMING.....6

8 REVIEW7

9 RECORDS.....7

10 EXCEPTIONS.....7

11 REFERENCE.....7

12 DOCUMENT POLICY HISTORY.....7

1 Overview and Purpose

PromptHalo Technologies (“the Company”) finds weaknesses before someone else does. This Policy says what is scanned, how findings are prioritised, and how quickly they are fixed.

The scanning itself is automated and continuous — no one has to remember to run it. What needs human attention is deciding what matters and confirming it was actually fixed.

2 Scope

This Policy covers the AWS estate, the code and its dependencies in GitHub, and the models and agents the Company runs. It does not extend to personally owned devices, where the operating system's own updates are relied on under the Acceptable Use Policy.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
5. **Exploitability** — whether a weakness can realistically be reached and used in the Company's own environment, as opposed to in principle.
6. **Finding** — a weakness reported by a scan, a test or a person, before it has been triaged.
7. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
8. **Patch** — a vendor-supplied fix, as distinct from a configuration change or a compensating control.

9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 What Is Scanned

1. Code dependencies are scanned continuously by the code host, which raises a finding when a new advisory affect something the Company uses. [SOC 2: CC7.1, CC4.1]
2. Production infrastructure is scanned at least monthly against the adopted baselines in the Cloud Platform Standard. This is automated and produces its own record; monthly here means the scan, not a meeting. [SOC 2: CC7.1, CC4.1]
3. Secrets committed to the repository are detected by the code host's secret scanning, which is treated as a finding of the highest criticality because the window is already open. [SOC 2: CC7.1, CC6.7]
4. Models and agents are assessed before release and on significant change for weaknesses specific to them — prompt injection, tool misuse and unintended data reach — through the check in the AI Governance Policy rather than a separate exercise. [SOC 2: CC7.1]

6 Deciding What Matters

1. Criticality comes from technical severity adjusted for whether the weakness is reachable in the Company's actual environment. A critical score on something not exposed is not a critical finding, and saying so in the record is what keeps the queue honest. [SOC 2: CC7.1]
2. Anything on a published exploited-vulnerabilities list is treated as reachable until shown otherwise. [SOC 2: CC7.1]
3. Target times are set by criticality and recorded with the finding. Where a target will be missed, the reason and the new date are recorded rather than the date quietly moving. [SOC 2: CC7.1, CC4.2]

7 Fixing and Confirming

1. A fix is applied through the normal change path. Where a patch is not available, a compensating control is applied and recorded, and the finding stays open until the patch lands. [SOC 2: CC7.1, CC8.1]
2. Corrective action is verified as effective before a finding is closed — the scan must stop reporting it, or the change must be demonstrably in place. “Reported as done” is not closed. [SOC 2: CC4.2]

3. Findings that recur are escalated rather than closed again. A weakness fixed three times is a process problem, not three findings. [SOC 2: CC4.2]
4. Findings and their dispositions live in the plan of action under the Information Security Policy, which is the Company's single deficiency population. [SOC 2: CC4.2]

8 Review

1. Once a year the Accountable Party reviews the finding population: what was found, how long things took against their targets, what recurred, and whether the scanning coverage still matches the estate. Where nothing notable arose, that is recorded. [SOC 2: CC4.1, CC4.2]
2. Scanning coverage is confirmed against the asset inventory at the same sitting — a scanner covering three of four accounts reports clean and means nothing. [SOC 2: CC7.1, CC2.1]

9 Records

1. Scan configuration and the systems in coverage. [SOC 2: CC7.1]
2. Findings with criticality, target date and disposition, held in the plan of action. [SOC 2: CC4.2]
3. Verification evidence for closed findings. [SOC 2: CC4.2]
4. The annual review record. [SOC 2: CC4.1]

10 Exceptions

Where a finding cannot be fixed — an unsupported component, or a fix that would break the service — the position is recorded by the Accountable Party with the compensating control and a review date and carried as a risk. Where no exceptions are in force, that is recorded affirmatively at the annual review.

11 Reference

1. SOC 2 Trust Services Criteria, Security category [CC4.1, CC4.2, CC7.1]
2. POL-ISP-001 Information Security Policy [SOC 2: CC4.2]
3. STD-CLD-001 Cloud Platform Standard [SOC 2: CC7.1]
4. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
5. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC7.1]
6. EU General Data Protection Regulation, Article 32

12 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release